

Gestión de Riesgos con SimpleRisk

Seguridad de Sistemas - Licenciatura en Sistemas de Información

Estudiante: Diego Daniel Jofré Winterstetter

Resumen ejecutivo

El análisis se realizó sobre el escenario de una clínica privada con 120 empleados y una atención aproximada de 800 pacientes por día. La organización utiliza historias clínicas digitales y gestiona información de pacientes, facturación y obras sociales.

A partir de este escenario se identificaron siete riesgos y se evaluaron con el método Classic de SimpleRisk. La herramienta combina probabilidad e impacto y, con la configuración utilizada, aplica la fórmula $(\text{Likelihood} \times \text{Impact}) \times (10 / 25)$.

Los resultados muestran que los riesgos que requieren mayor atención están vinculados con el compromiso de credenciales, ransomware, acceso no autorizado a historias clínicas, pérdida o corrupción de backups y disponibilidad de la infraestructura.

También se observa que varios riesgos pueden relacionarse entre sí. Por ejemplo, un ataque de phishing puede comprometer una cuenta y facilitar posteriormente accesos no autorizados o un ataque de ransomware.

Criterio utilizado

Los cinco riesgos principales quedaron clasificados como **Medium** por SimpleRisk. Por este motivo, para ordenarlos se utilizó además el puntaje numérico calculado por la herramienta. Cuando existieron empates, se priorizó su relación con la continuidad de los servicios y la exposición de información clínica.

Resultado general

7	5	3
riesgos evaluados	riesgos prioritarios	planes de acción

Conclusión de esta primera lectura: la prioridad no está en eliminar todos los riesgos, sino en reducir aquellos con mayor impacto y mejorar la capacidad de respuesta de la clínica.

Top 5 de riesgos

La siguiente priorización utiliza los valores verificados directamente en SimpleRisk:

#	Riesgo	Prob.	Impacto	Puntaje	Nivel
1	Compromiso de credenciales de empleados mediante phishing	Likely (4)	Major (4)	6.4	Medium
2	Ransomware sobre el sistema de gestión clínica	Credible (3)	Extreme / Catastrophic (5)	6.0	Medium
3	Acceso no autorizado a historias clínicas digitales	Credible (3)	Major (4)	4.8	Medium
4	Pérdida o corrupción de backups de la clínica	Credible (3)	Major (4)	4.8	Medium
5	Caída de la red interna de la clínica	Credible (3)	Major (4)	4.8	Medium

Lectura de los resultados. El phishing obtiene el mayor puntaje (6.4), seguido por ransomware (6.0). Aunque ransomware tiene una probabilidad menor, su impacto fue valorado como Extreme/Catastrophic debido a la posibilidad de afectar de forma simultánea sistemas, estaciones de trabajo, información clínica y mecanismos de recuperación.

Los riesgos de acceso no autorizado, backups y red interna obtienen 4.8. Se mantienen dentro del Top 5 porque afectan información sensible o la continuidad de servicios necesarios para el funcionamiento de la clínica.

Nota sobre el nivel. La configuración actual de SimpleRisk clasifica los cinco como Medium. El puntaje numérico permite establecer una prioridad interna dentro de esa misma categoría.

Relación entre riesgos

Phishing → credenciales comprometidas → acceso no autorizado / ransomware. Esta relación muestra por qué una misma medida preventiva, como MFA o capacitación, puede contribuir a reducir más de un riesgo.

Planes de acción y recomendaciones

Se definieron tres planes de mitigación sobre riesgos priorizados. En esta etapa las acciones se encuentran planificadas y todavía no se considera una reducción del riesgo residual.

Riesgo	Plan de acción	Responsable	Fecha	Presupuesto	Estado
Ransomware	Protección y recuperación frente a ransomware	Responsable de TI	10/10/2026	USD 3.000	Planificado
Phishing	Fortalecimiento de autenticación y prevención de phishing	Responsable de TI	10/10/2026	USD 2.000	Planificado
Backups	Fortalecimiento de la estrategia de backups	Responsable de TI	10/10/2026	USD 2.500	Planificado

Presupuesto estimado total de los tres planes: USD 7.500

Recomendaciones prioritarias

- 1. Fortalecer la autenticación:** Implementar MFA en cuentas que acceden a sistemas críticos y revisar periódicamente los permisos asignados.
- 2. Reducir la exposición a phishing:** Capacitar al personal y complementar la medida con controles de correo y detección de accesos anómalos.
- 3. Mejorar la protección frente a ransomware:** Mantener equipos actualizados, reforzar la protección de endpoints y segmentar la red para limitar la propagación.
- 4. Asegurar la recuperación:** Mantener copias de seguridad aisladas o inmutables y realizar pruebas periódicas de restauración.
- 5. Revisar los riesgos periódicamente:** Actualizar probabilidad, impacto y riesgo residual a medida que se implementen controles o aparezcan nuevas amenazas.

Conclusión

SimpleRisk permitió ordenar y comparar los principales riesgos del escenario y asociarlos con acciones concretas. Como resultado, la prioridad inicial se concentra en identidad y accesos, protección frente a ransomware y recuperación mediante backups. Los planes propuestos representan un punto de partida y deberían reevaluarse una vez implementados los controles.